Page No.
Date

Case study : Securing the university Examination System.

A university uses an Operating system based examination management system to store student records, examination marks, faculty details, and question papers. The system has three main user groups: Students, faculty, and administrators. Students should be able to view only their own marks and download permitted learning materials.

Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identified the following events.

At 10:00, the account student07 has three failed login attempts.
At 10:03, student007 has successfully logs in.
At 10:04, student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
At 10:05, the system records an attempted modification of ExamMarks.xlsx by student07.
At 10:15 Faculty02 modifies marks in ExamMarks.xlsx and saves the file successfully.
At 10:20, an administrator discovers that a former faculty member's account is still active.
The auditing log is stored on the same server, and user-level permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity and availability ; prevent unauthorized access, maintain accountability and investigate suspicious activity.

You are asked to recommend appropriate O.S access-control, security-administration, and auditing measures

Questions.

Q1] Identify the main security problems in the case study List atleast 4 risks or weaknesses indicated by the scenario.

Q2] Explain the differences between authentication and authorization using student07 as an example.
—— Distinguish identity verification from permission checking.

Q3] Recommend an access-control policy for students, faculty and Administrators. Justify your choices.
Consider how permissions should be assigned and managed.

Q4] Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx.
—— Specify appropriate Read, Write, and Delete permissions for each user group.

Q5] Explain how the Principle of Least privilege

should be applied in this system.
State what each group needs to do and which unnecessary permissions should be removed.

Q6. Interpret the audit events from 10:00 to 10:05. What should the security team do next?
Explain why the sequence is suspicious without assuming that it proves an attack.

Q7. Identify at least five events that should be recorded in the audit logs.
Include login, file, account, permission / administrative events

Q8. Explain why the audit logs must be protected and recommend

Q 4] ① At 10:00 the account student 07 has 3 failed attempts which indicates that there is a password related problem.

② At 10:04, student tries to login and attempts to open exammarks.xlsx which includes marks of all the students, student should not have the permisson to access marks of all students which is a security risk.

③. A former ~~Secuir~~ administrator account is active. which is also a major security weakness.

Q2] Authentification means verifying the identity of a user. In this case student 07 has 3 failed login attempts

Authorization means the actions which the user is permitted to perform. for ex the faculty members need to view student records and enter or modify marks.

Q3] The university should use Role-Based Access Control:

As follows ⟶

students — Can view their own marks and download permitted learning materials.

Faculty — Can view students records and enter or modify marks for their assigned subjects.

Administrators — Can manage user accounts, permissions and system configuration.

Q4]

user groups.	Read	Write	Delete
students.	Own marks only through an authorized View	No	No
Faculty	yes, for assigned students or subjects.	Yes for assigned marks.	No.
Administrators.	When required for administration.	when required and authorized	only when

This Access Control list protects confidential student records.
— student cannot modify or delete marks, faculty can update marks, and administrators receive only the permissions needed for their duties.

Q5

The principle of least Privilege means giving users only the permissions they need to perform their work.
1. students : Can view their own marks and download permitted study material but cannot modify marks or access other students marks.
2. faculty — Can view student records and enter or modify marks but cannot manage user accounts.

⑤ Administrator - Can manage user accounts and permissions according to their responsibilities.
④ Former administrators - Their account should be immediately deactivated.

Q6]

- The sequence of events is suspicious because Student 07 makes three failed login attempts at 10:00, successfully logs in at 10:03, attempts to open ExamMarks.xlsx at 10:04, and attempt to modify the file at 10:05.

- The security team should.
- Review login records.
- check whether student 07 was authorized to access the marks file.
- Investigate whether any marks were actually changed.
Preserve the audit logs and check for other suspicious activities.

Q7]

- The system should record:
- Successful and failed login attempts.
- Attempts to open or access files.
- Changes to student marks.
- Changes to roles and access permissions.

- These records helps university identify suspicious activities.

Q8.

— Audit logs must be protected because they provides evidence of user activities.

— If someone modifies or deletes the logs, the university may lose important evidence during an investigation.

— Two ways to protect them are:

— Restrict access: Only authorized security personnel should be able to manage the logs.

— use tamper-resistant storage: Store logs on a separate, protected server.

— These measures helps maintain the accuracy.

Q9.

— The university should immediately disable the former faculty members accounts and revoke their access to University systems.

— It should also terminate active sessions, review the account's previous activities

— This is important because former faculty members no longer require access to university resources

Disabling it reduces the risk of unauthorized access and data misuse.

Q10.

Page No.
Date

Investigate - Review the audit logs, verify student 07's activities and check whether any marks were changed without authentication

Review access - Disable the former faculty member's account and examine the permissions of students, faculty, and administrative.

Improve Security : Apply RBAC and the principle of Least Privilege.

Monitor regularly : Protect audit logs, review suspicious activities.

These steps will help protect confidential Student records.